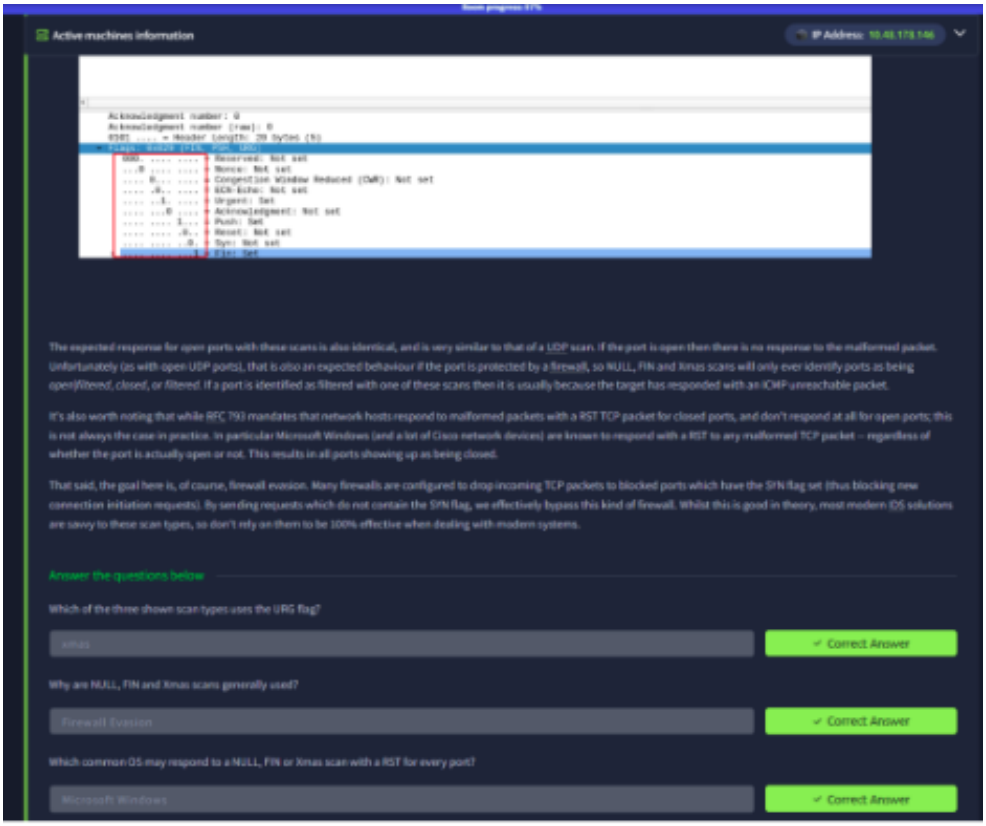
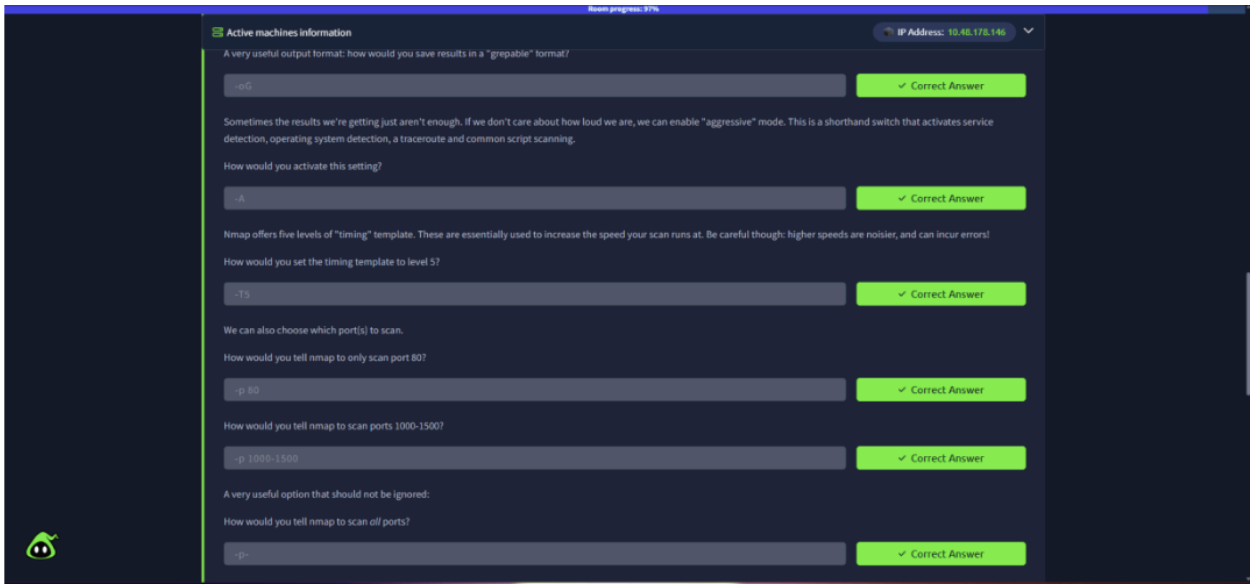
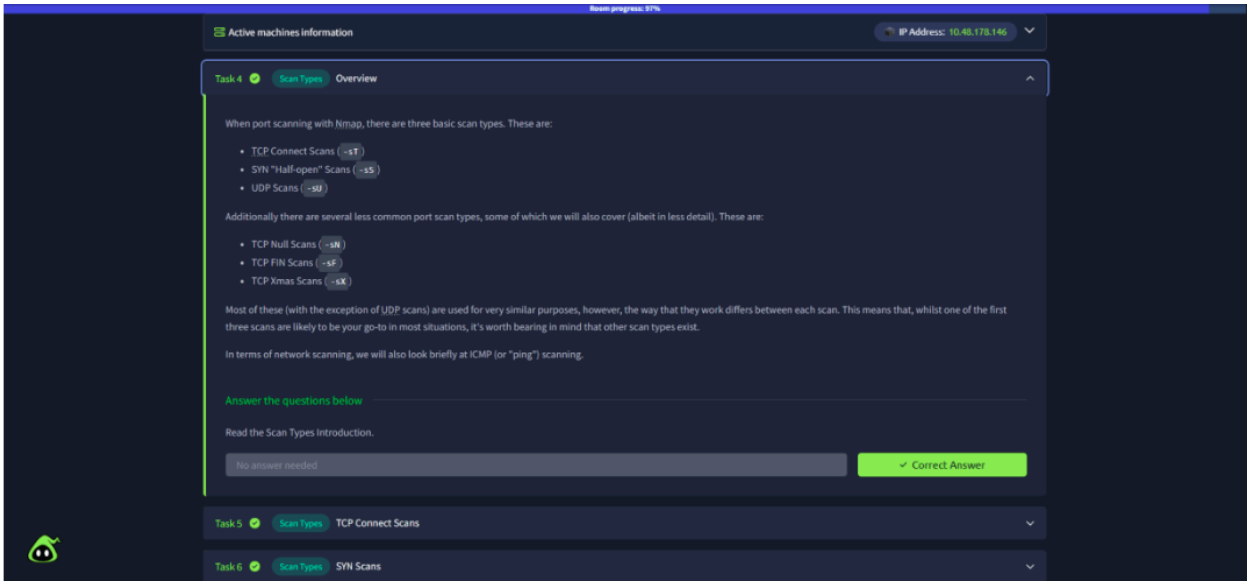
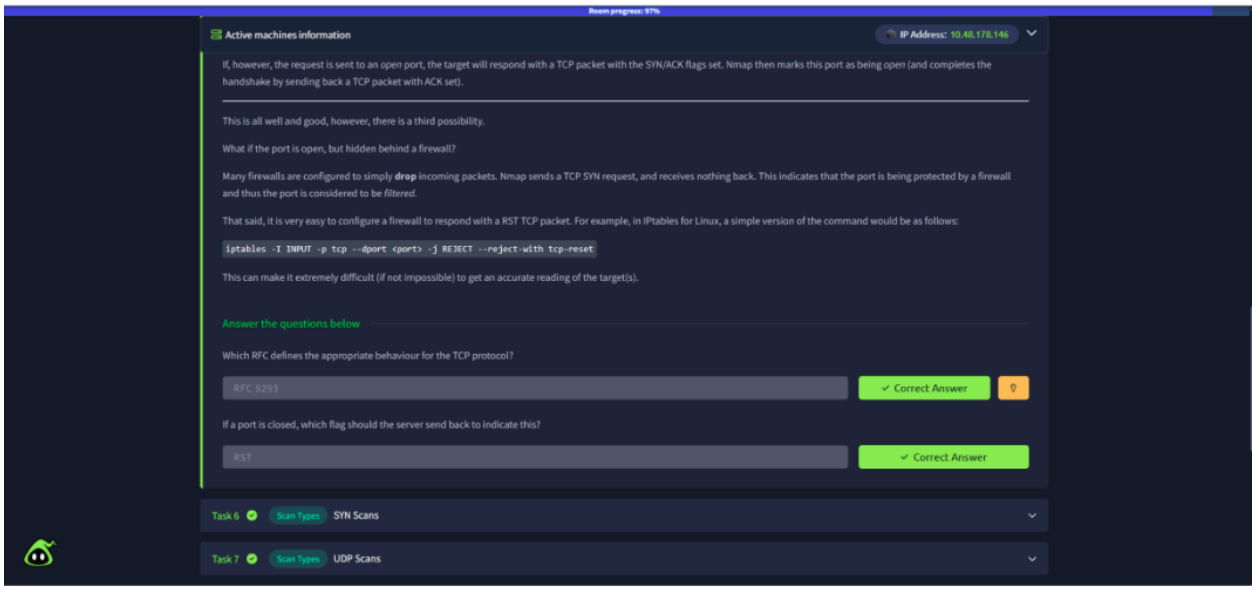
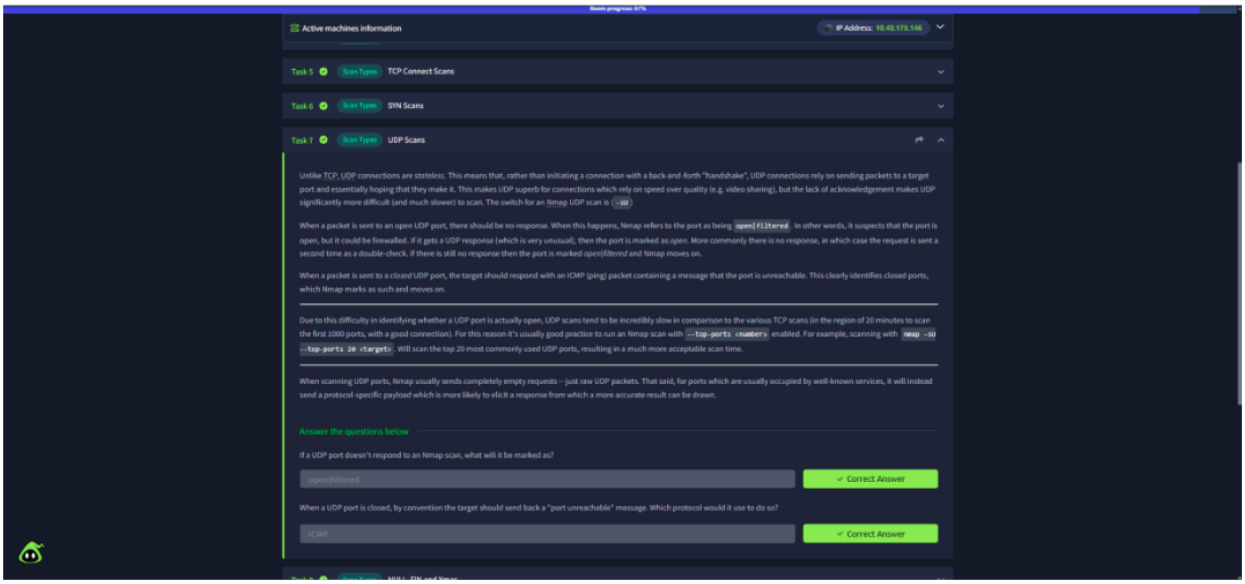
# EXPERIMENT 12
## Discover Live Hosts Using Nmap Scans

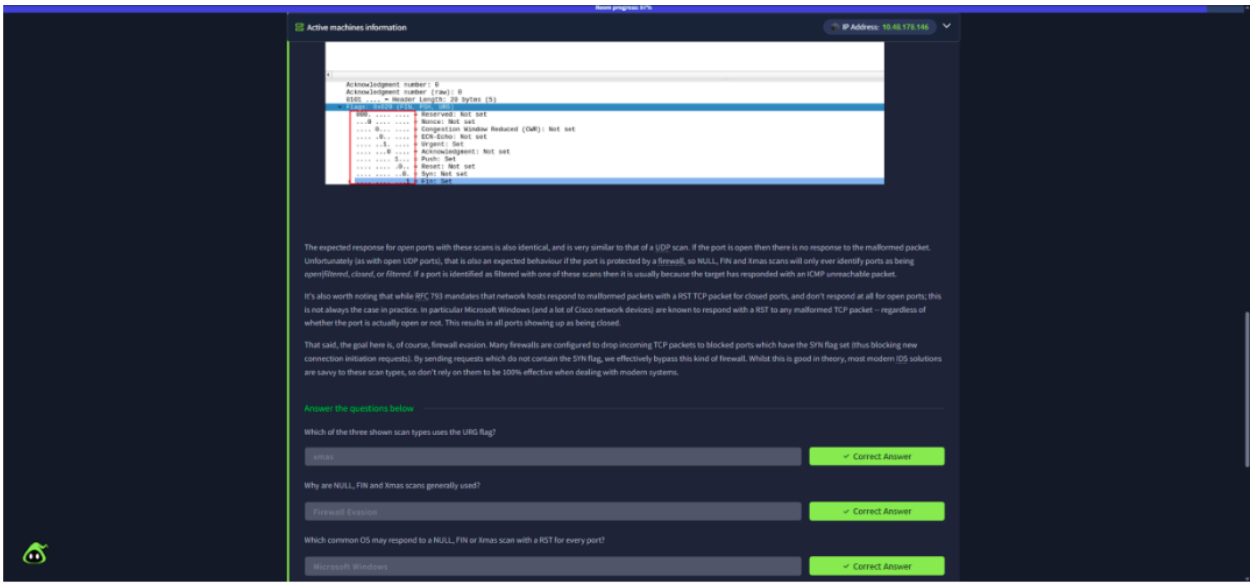



Room progress: 97%
Active machines information
IP Address: 10.48.178.146
Task 4
Scan Types
Overview
When port scanning with Nmap, there are three basic scan types. These are:
TCP Connect Scans (-sT)
SYN "Half-open" Scans (-sS)
UDP Scans (-sU)
Additionally there are several less common port scan types, some of which we will also cover (albeit in less detail). These are:
TCP Null Scans (-sN)
TCP FIN Scans (-sF)
TCP Xmas Scans (-sX)
Most of these (with the exception of UDP scans) are used for very similar purposes, however, the way that they work differs between each scan. This means that, whilst one of the first three scans are likely to be your go-to in most situations, it's worth bearing in mind that other scan types exist.
In terms of network scanning, we will also look briefly at ICMP (or "ping") scanning.
Answer the questions below
Read the Scan Types Introduction.
No answer needed
Correct Answer
Task 5
Scan Types
TCP Connect Scans
Task 6
Scan Types
SYN Scans


Room progress: 97%
Active machines information
IP Address: 10.48.178.146
If, however, the request is sent to an open port, the target will respond with a TCP packet with the SYN/ACK flags set. Nmap then marks this port as being open (and completes the handshake by sending back a TCP packet with ACK set).
This is all well and good, however, there is a third possibility.
What if the port is open, but hidden behind a firewall?
Many firewalls are configured to simply drop incoming packets. Nmap sends a TCP SYN request, and receives nothing back. This indicates that the port is being protected by a firewall and thus the port is considered to be filtered.
That said, it is very easy to configure a firewall to respond with a RST TCP packet. For example, in IPtables for Linux, a simple version of the command would be as follows:
iptables -I INPUT -p tcp --dport <port> -j REJECT --reject-with tcp-reset
This can make it extremely difficult (if not impossible) to get an accurate reading of the target(s).
Answer the questions below
Which RFC defines the appropriate behaviour for the TCP protocol?
RFC 9293
Correct Answer
If a port is closed, which flag should the server send back to indicate this?
RST
Correct Answer
Task 6
Scan Types
SYN Scans
Task 7
Scan Types
UDP Scans


Active machines information
IP Address: 10.48.173.146
Task 5 Scan Types TCP Connect Scans
Task 6 Scan Types SYN Scans
Task 7 Scan Types UDP Scans
Unlike TCP, UDP connections are stateless. This means that, rather than initiating a connection with a back-and-forth "handshake", UDP connections rely on sending packets to a target port and essentially hoping that they make it. This makes UDP superb for connections which rely on speed over quality (e.g. video sharing), but the lack of acknowledgement makes UDP significantly more difficult (and much slower) to scan. The switch for an Nmap UDP scan is (-sU)
When a packet is sent to an open UDP port, there should be no response. When this happens, Nmap refers to the port as being open|filtered. In other words, it suspects that the port is open, but it could be firewalled. If it gets a UDP response (which is very unusual), then the port is marked as open. More commonly there is no response, in which case the request is sent a second time as a double-check. If there is still no response then the port is marked open|filtered and Nmap moves on.
When a packet is sent to a closed UDP port, the target should respond with an ICMP (ping) packet containing a message that the port is unreachable. This clearly identifies closed ports, which Nmap marks as such and moves on.
Due to this difficulty in identifying whether a UDP port is actually open, UDP scans tend to be incredibly slow in comparison to the various TCP scans (in the region of 20 minutes to scan the first 1000 ports, with a good connection). For this reason it's usually good practice to run an Nmap scan with --top-ports <number> enabled. For example, scanning with nmap -sU --top-ports 20 <target>. Will scan the top 20 most commonly used UDP ports, resulting in a much more acceptable scan time.
When scanning UDP ports, Nmap usually sends completely empty requests -- just raw UDP packets. That said, for ports which are usually occupied by well-known services, it will instead send a protocol-specific payload which is more likely to elicit a response from which a more accurate result can be drawn.
Answer the questions below
If a UDP port doesn't respond to an Nmap scan, what will it be marked as?
open|filtered
Correct Answer
When a UDP port is closed, by convention the target should send back a "port unreachable" message. Which protocol would it use to do so?
ICMP
Correct Answer


Active machines information
IP Address: 10.48.173.146
Acknowledgment number: 0
Acknowledgment number (raw): 0
0101 .... = Header Length: 20 bytes (5)
Flags: 0x002 (SYN)
000. .... .... = Reserved: Not set
...0 .... .... = Nonce: Not set
.... 0... .... = Congestion Window Reduced (CWR): Not set
.... .0.. .... = ECN-Echo: Not set
.... ..0. .... = Urgent: Not set
.... ...0 .... = Acknowledgment: Not set
.... .... 0... = Push: Not set
.... .... .0.. = Reset: Not set
.... .... ..0. = Syn: Not set
.... .... ...0 = Fin: Not set
The expected response for open ports with these scans is also identical, and is very similar to that of a UDP scan. If the port is open then there is no response to the malformed packet. Unfortunately (as with open UDP ports), that is also an expected behaviour if the port is protected by a firewall, so NULL, FIN and Xmas scans will only ever identify ports as being open|filtered, closed, or filtered. If a port is identified as filtered with one of these scans then it is usually because the target has responded with an ICMP unreachable packet.
It's also worth noting that while RFC 793 mandates that network hosts respond to malformed packets with a RST TCP packet for closed ports, and don't respond at all for open ports; this is not always the case in practice. In particular Microsoft Windows (and a lot of Cisco network devices) are known to respond with a RST to any malformed TCP packet -- regardless of whether the port is actually open or not. This results in all ports showing up as being closed.
That said, the goal here is, of course, firewall evasion. Many firewalls are configured to drop incoming TCP packets to blocked ports which have the SYN flag set (thus blocking new connection initiation requests). By sending requests which do not contain the SYN flag, we effectively bypass this kind of firewall. Whilst this is good in theory, most modern IDS solutions are savvy to these scan types, so don't rely on them to be 100% effective when dealing with modern systems.
Answer the questions below
Which of the three shown scan types uses the URG flag?
xmas
Correct Answer
Why are NULL, FIN and Xmas scans generally used?
Firewall Evasion
Correct Answer
Which common OS may respond to a NULL, FIN or Xmas scan with a RST for every port?
Microsoft Windows
Correct Answer